

Data Ethics Practical 3

Data Protection Impact Assessment

Author: 150008022

April 7, 2020



"There is only one way at the end of the day to make
technology better and that is to use it"

Brad Smith, Microsoft President, 2020

Part I

DPIA

Step 1: Identify the need for a DPIA

Explain broadly what project aims to achieve and what type of processing it involves. You may find it helpful to refer or link to other documents, such as a project proposal. Summarise why you identified the need for a DPIA.

Microsofts' general purpose Face software can extract features such as age, emotion, gender, pose, smile, and facial hair from images of humans [1]. Images can be cross referenced to determine if the same person appears in them, and emotions can be detected based on facial features. West provides a compilation of current and future applications for facial recognition[2], which range from unlocking mobile devices to identifying and finding missing children.

These features require an assessment of the impact of the envisaged processing operations on the protection of personal data, as they meet the requirement of Article 35(3)(a) [3]: the facial recognition software attempts to profile individuals based on their appearance. The results of this profiling will likely be used to make decisions that affect the individual being profiled.

The project also requires a DPIA according to the UK ICO's guidance as it involves:

- carrying out profiling on a large scale.
- processing of biometric data.
- process personal data that could result in a risk of physical harm in the event of a security breach.

Step 2: Describe the processing

Describe the nature of the processing: how will you collect, use, store and delete data? What is the source of the data? Will you be sharing data with anyone? You might find it useful to refer to a flow diagram or other way of describing data flows. What types of processing identified as likely high risk are involved?

Figure 1 shows an example of the facial recognition API usage flow for reference. The Face API processes three different categories of data [4]:

- **Customer Data:** any data provided by a customer using the service, such as images of faces and metadata attached to people and groups. Usernames and billing information is also included in this category.
- **Service Generated Data:** logs and usage monitoring data which contains pseudonymized data.
- **Support Data:** information provided by the customer when seeking technical support with the service. For example, emails asking how to use the service or how to resolve an issue.

Collect Consumers of the cognitive services API (Application Program Interface) provide customer data which is used by the software. This includes images of people for identification and training. The URL of images are provided using HTTPS (Hypertext Transfer Protocol Secure), which are then fetched by the service to be processed. Service generated data is produced by the servers that process user requests. Support data is supplied by customers and the technical support team.

Use None of the images submitted are retained in their raw form. Instead, images are deconstructed on submission into face landmarks (coordinates of facial features) and attributes (age, emotion, gender, etc.) [5]. The face landmarks can be used to identify the same person appearing in different images, and for assessing their emotion or demographic. Users are also able to attach custom metadata to any group or person that they create using the API. Service generated data is used to determine billing of users, and for maintenance of the software. Support data is used to identify usability issues with the software and help solve customer issues.

Store Processing and storage occurs in the cloud, specifically using Azure. Users can choose the geographical region that they would like their data to be stored. Data is stored using a multi-tenant approach, where multiple customers data will be stored on the same hardware [6]. However, the data is segregated such that users cannot access data they do not own. Azure staff are unable to access the data without explicit permission from a user, and any access and is heavily monitored. Access to the data and model requires a cryptographic key. Two key types exist: an admin key which gives full rights to all operations and a query key which gives read-only access. Keys can be created and revoked by users with the necessary permissions [7].

Delete The documentation shows that consumers of the API can delete anything they create (groups of people, individual people, face metadata) with immediate effect [8]. When users delete data or remove their accounts, their data is destroyed by being overwritten. Physical hardware when decommissioned is also destroyed.

Sharing Customer data is not shared with any third parties, and is not accessible by default to Microsoft. This is achieved through access control, network security, and encryption of data at rest.

High Risk Areas of high risk include the transit of data between user and the service, and the storage of the data and model. Data has the potential to be intercepted or accessed by an unauthorized entity at any of these stages. Any logging of processes also has the potential to leak data. The preprocessing of the images to determine attributes such as gender also has a high level of risk. Both correct and incorrect classifications could influence individuals that are processed by the system.

Describe the scope of the processing: what is the nature of the data, and does it include special category or criminal offence data? How much data will you be collecting and using? How often? How long will you keep it? How many individuals are affected? What geographical area does it cover?

Nature of the data Customer data that will be processed includes raw images of faces that are supplied by the user, descriptions of faces detected by the service in these images as coordinates, generated categorisation data such as gender, emotions, and any metadata that the users tag groups/people/images with themselves.

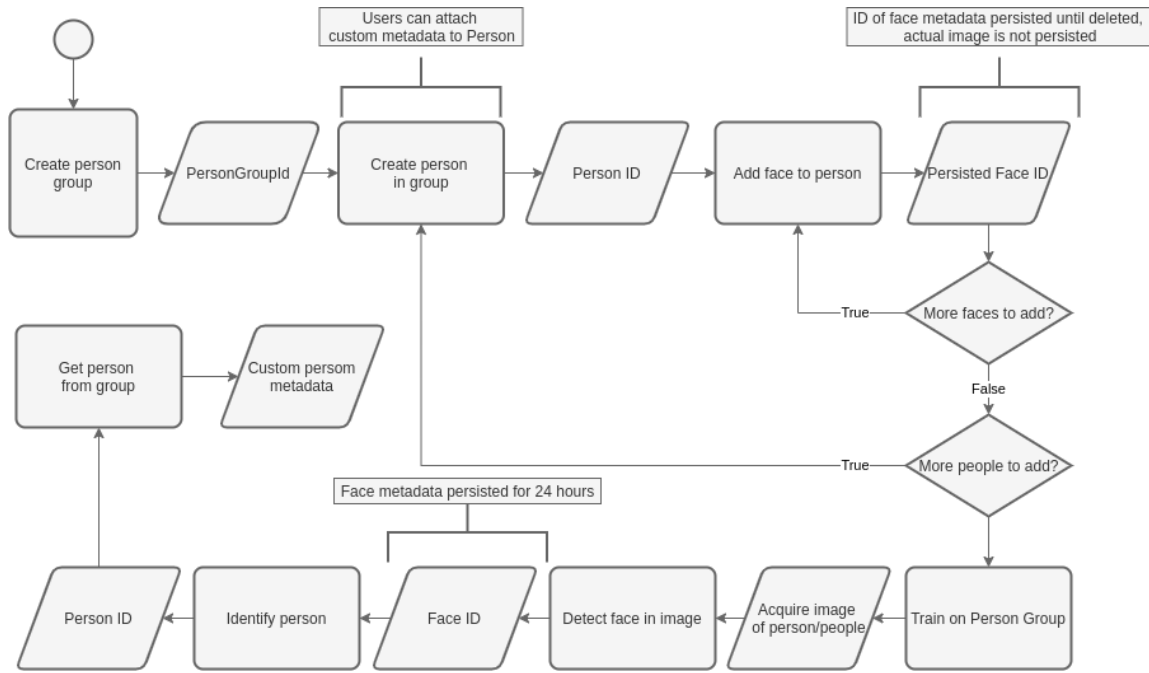


Figure 1: Usage flow for person identification

Special category or criminal offence Only the user supplied metadata is not essential to use the service. This data comes under GDPR special category data as it can be considered biometric data used to identify an individual. Service generated data such as logs will likely contain the IP addresses of users and their usernames, which are considered personal data according to recital 30 of GPDR [9] and by the UK ICO [10] respectively. Microsoft has no control over what data is stored under the user supplied metadata, ad so it is the responsibility of the user to determine appropriate use of this feature.

How much data Each group can contain up to 1 million different person objects, and each person can have up to 248 faces registered [11]. There is virtually no limit on the number of groups that users can create.

How often is data collected Service generated data such as logs will be collected every time a user interacts with the service. Customer data is only collected when explicitly provided by the customer.

How long is data kept Processed face images for identification purposes are kept for 24 hours unless deleted by the user. Persisted faces used for model training are retained until deleted by the user.

How many individuals are affected The number of individuals affected corresponds to the number of people and faces submitted to the service, as well as the number of users of the service. Both are potentially limitless.

What geographical area does it cover The Face API is available essentially worldwide. More details can be found at [12].

Describe the context of the processing: what is the nature of your relationship with the individuals? How much control will they have? Would they expect you to use their data in this way? Do they include children or other vulnerable groups? Are there prior concerns over this type of processing or security flaws? Is it novel in any way? What is the current state of technology in this area? Are there any current issues of public concern that you should factor in? Are you signed up to any approved code of conduct or certification scheme (once any have been approved)?

What is the nature of your relationship with the individuals Consumers of the face API are customers.

How much control will they have Customers are able to see, update, and delete any of their data uploaded to the service using HTTP endpoints.

Would they expect you to use their data in this way How the Face API uses data is made explicitly clear in its documentation. The process of accumulating training data to build a model and using it for classification as is done by the service is very typical for this area of technology.

Do they include children or other vulnerable groups The service could potentially process children or vulnerable groups. It is dependent on the consumer of the service to determine appropriate usage of the service if any of these groups are involved.

Are there prior concerns over this type of processing or security flaws Data at-rest and in-transit are all secured using state-of-the-art methods. There are concerns that facial recognition could be used for malicious purposes and automated decision making.

Is it novel in any way Facial recognition technology has been researched since the 1960s [13]. Facial recognition as a service is also not novel.

What is current state of technology in this area Facial recognition technology is currently used by police during investigations and has proven effective in combating crime such as child sexual exploitation and knife crime in the UK [14]. Vendors of facial recognition technology have been evaluated on an almost yearly basis by the National Institute of Standards and Technology (NIST) [15]. The difficulty of these evaluations have also increased over time as the technology has improved.

Are there any current issues of public concern that you should factor in The main public concerns towards facial recognition technology are that of privacy violations and accuracy of the algorithms [16]. There have also been issues with bias in models which can potentially result in the violation of laws regarding discrimination [17]. For example, the software often works better for white men than other groups [18]. Widespread usage of facial recognition technology could also have ramifications for democratic freedoms if coupled with mass surveillance by governments.

Are you signed up to any approved code of conduct or certification scheme (once any have been approved) Microsoft Azure has more compliance certifications than any other cloud service provider. The list can be found at [19].

Describe the purposes of the processing: what do you want to achieve? What is the intended effect on individuals? What are the benefits of the processing – for you, and more broadly?
--

What do you want to achieve The Face API hopes to allow other innovators to incorporate the technology into their own projects to solve problems.

What is the intended effect on individuals The intended effect on individuals is to help technology progress to make the world safer.

What are the benefits of the processing - for you, and more broadly The processing allows anyone to attempt to innovate with facial recognition technology. Microsoft are able to charge a fee based on how users consume the service.

Step 3: Consultation process

Consider how to consult with relevant stakeholders: describe when and how you will seek individuals' views – or justify why it's not appropriate to do so. Who else do you need to involve within your organisation? Do you need to ask your processors to assist? Do you plan to consult information security experts, or any other experts?

Describe when and how you will seek individuals' views Microsoft actively seeks advice from governments and regulators on how to ensure appropriate use of facial recognition technology [20]. Since the project will collect the personal data of individuals not yet identified, a public consultation process will be carried out, as advised by the ICO [21].

Who else do you need to involve within your organisation Developers of the service and security experts employed by Microsoft will be involved to ensure that the privacy and security requirements required by this project are possible and will be delivered. In the documentation for the project, the controller also encourage any users of the service to provide proactive and reactive communication to stakeholder concerns and feedback [22].

Step 4: Assess necessity and proportionality

Describe compliance and proportionality measures, in particular: what is your lawful basis for processing? Does the processing actually achieve your purpose? Is there another way to achieve the same outcome? How will you prevent function creep? How will you ensure data quality and data minimisation? What information will you give individuals? How will you help to support their rights? What measures do you take to ensure processors comply? How do you safeguard any international transfers?

What is your lawful basis for processing Our lawful basis for processing is consent, as the individual using our service has given clear consent for the controller to process their personal data for a specific purpose [23]. It is dependent on the individuals using our service to provide a lawful basis for processing if the data being provided to our service is not theirs.

Does the processing actually achieve your purpose The project has proven to be able to create working models capable of providing all the advertised functionality. Face detection and matching of faces in different images work reliably. Attribute detection such as determining emotion and sex detection are currently not as accurate as the other features of the project, but this is made clear in documentation.

Is there another way to achieve the same outcome It is not possible to perform automated facial recognition without processing images of faces. The task could be performed manually by humans, but this would be far more time intensive and likely more error prone.

How will you prevent function creep As advised by the ICO, Microsoft will regularly review the processing being performed by the Face API [24]. Documentation and privacy information will also be reviewed to ensure that the purpose of the project has not changed with time.

How will you ensure data quality and data minimisation Customer data that is used directly for face recognition will require the user to ensure data quality and minimisation, as Microsoft will not have any access to this data when it is persisted using the service. To ensure data minimisation is exercised, data usage will also be regularly reviewed. Any data that users request is deleted will be done so immediately.

What information will you give individuals Documentation will be made available to all users of the service describing how and what data is processed by the service. Guidance will also be provided to help users of the service deploy it responsibly in their own software. This will include guidance regarding how to help the software produce accurate results, and how to ensure their own usage of the software is compliant with regulations [22].

How do you safeguard any international transfers Cognitive Services allow users to specify the region where they would like their data to be stored. Data may be replicated for resiliency within the specified region.

Step 5: Identify and assess risks

Describe source of risk and nature of potential impact on individuals. Include associated compliance and corporate risks as necessary.	Likelihood of harm	Severity of harm	Overall risk
1. The software might be used to fully automate decisions rather than supplement human judgement, which could result in individuals being denied access to services or opportunities	Probable	Severe	High
2. Bias present in the models could discriminate against certain groups	Possible	Severe	High
3. Customer data is leaked or accessed by an unauthorized member of staff	Remote	Severe	Low
4. Users may share unnecessary personal data when communicating with technical support staff	Possible	Medium	Medium
5. Users may accidentally leak their API key to another person	Possible	Severe	High
6. Personal data may be leaked in service generated data such as logs	Possible	Medium	Medium

Step 6: Identify measures to reduce risk

Identify additional measures you could take to reduce or eliminate risks identified as medium or high risk in step 5				
Risk	Options to reduce or eliminate risk	Effect on risk	Residual risk	Measure approved
1	Documentation such as the transparency note [22] will inform users that the software should only be used to supplement human judgement.	Reduced	High	Yes/no
2	Developers and research staff will be trained to detect and minimise bias in models.	Reduced	Medium	Yes/no
3	Strict monitoring of employee interactions with the system will be in place to detect any occurrence of this event. Support staff will only be granted the least privilege required to complete the task requested by a customer.	Eliminated reduced accepted	Low medium high	Yes/no
4	Staff will be trained to be explicit about what information they require from customers to carry out a task. Personal data will be censored or anonymized where possible. For example, in emails. Before engaging with support staff, customers will be informed that they should not share any personal information during the communication that is not necessary to resolve their issue.	Reduced	Low	Yes/no
5	Service generated data will be anonymized or pseudonymized before being made visible to staff. Any personal data that is not filtered by automated methods will be removed by other means.	Reduced	Low	Yes/no

Step 7: Sign off and record outcomes

Item	Name/position/date	Notes
Measures approved by:		Integrate actions back into project plan, with date and responsibility for completion
Residual risks approved by:		If accepting any residual high risk, consult the ICO before going ahead
DPO advice provided:		DPO should advise on compliance, step 6 measures and whether processing can proceed
Summary of DPO advice:		
DPO advice accepted or overruled by:		If overruled, you must explain your reasons
Comments:		
Consultation responses reviewed by:		If your decision departs from individuals' views, you must explain your reasons
Comments:		
This DPIA will kept under review by:		The DPO should also review ongoing compliance with DPIA

Part II

Critical Assessment

1 Introduction

Microsoft's Face API is part of its family of Azure Cognitive Services. These are general purpose artificial intelligence services that allow other developers to utilise the technology without having to understand and design models and algorithms themselves. Completing the DPIA for the Face API specifically felt unsatisfying because of its 'software-as-a-service' nature.

To measure what was unsatisfactory about using the DPIA, the Cigref code of ethics [25] will be compared to the Microsoft’s [17]. The former was chosen as it includes a discussion of duty-based ethics, which it could be argued that the DPIA fails to cover. The latter allows us to discuss if Microsoft themselves have recognised any form of duty-based ethics.

1.1 Cigref

Ethics by Design The Cigref code of ethics provides multiple preliminary questions to help ensure ethics by design. One such question is “Are solutions designers representative of the social and gender diversity of society”. In our case study, this could be important as a lack of representation of minorities and disadvantages groups may result in issues such as bias being taken less seriously. From Microsoft’s diversity reports [26], there is definitely an effort being made to minimise this issue. They also recognise that this remains an issue with their own facial recognition services, and are continuing to improve upon them. The DPIA and ICO guidance does not place a strict measure on ‘how much’ bias is acceptable, allowing controllers to deploy their technology without much consideration for bias.

Despite Microsoft’s code of ethics agreeing with this need to avoid technology resulting in unlawful discrimination, they have deployed their facial recognition software regardless. It could be argued that they should not have made the software available until the bias present in their models was greatly reduced. Microsoft followed the DPIA guidance of seeking feedback from stakeholders and individuals that would be affected by the system and regularly discuss with authorities how to best regulate the technology. Their own code of ethics even highlights a need for this regulation to mature before the technology should be fully deployed, while making the technology widely available to be abused without regulation. This is a clear case of ethics washing, which the DPIA has failed to prevent.

On the other hand, the DPIA enforces protection of privacy and personal data well. The case study exemplifies this. The Face API includes methods for deleting any data that users are able to submit to the service. The thorough approach to the deletion of data on physical hardware satisfies the right to be forgotten which is required by the Cigref code of ethics and GDPR.

Ethics of Use The DPIA includes support for the concept of ‘joint controllers’ [27]. For example, an organisation that produces a piece of software which uses Microsoft’s Face API could be considered joint controllers with Microsoft. The ICO guidance states that joint controllers must arrange between themselves who will take

primary responsibility for ensuring GDPR compliance. Individuals and authorities can take action against any controller if compliance is breached. This could be a considered an implementation of Cigrefs preliminary question regarding partnership ethics:

Is there a policy allowing you to check, when digital solutions are built by a number of partners, that the whole process is ethical?

Microsoft emphasise in their own DPIA guidance that they have no control over what data their service is used to store, and that "it is incumbent upon the data controller to determine appropriate use of the data controller's data" [4]. There is no review process performed by Microsoft to ensure that those utilising their services are exercising appropriate processing either, therefore their approach to partnership ethics is very one directional.

Societal Ethics Cigref's societal ethics considers the environmental, societal, and economic impact of a technology. The DPIA only requires a consideration of the societal effect that a technology could have. Therefore, a project that requires a large amount of servers will not be prompted to consider how they could minimise or offset the carbon footprint produced through power consumption. The automation of tasks can have extreme effects on the availability of jobs, and our case study is no exception. Microsoft insist that technology should be used to supplement not replace human processing in their code of ethics, and Cigref also ask that an assessment be carried out to determine the impact of innovations on jobs. The DPIA does not require this kind of analysis.

2 Conclusion

The DPIA is effective at forcing data controllers to comply with some aspects of the Cigref code of ethics.

References

- [1] *Facial Recognition: Microsoft Azure*. URL: <https://azure.microsoft.com/en-gb/services/cognitive-services/face>.
- [2] *21 Amazing Uses for Face Recognition – Facial Recognition Use Cases*. Oct. 2019. URL: <https://www.facefirst.com/blog/amazing-uses-for-face-recognition-facial-recognition-use-cases/>.

- [3] *Article 35 EU GDPR "Data protection impact assessment"*. European Commission. May 25, 2018. URL: <https://www.privacy-regulation.eu/en/article-35-data-protection-impact-assessment-GDPR.htm> (visited on Mar. 30, 2020).
- [4] Robmazz. *DPIA Azure for the GDPR - Microsoft GDPR*. URL: <https://docs.microsoft.com/en-us/microsoft-365/compliance/gdpr-dpia-azure?view=o365-worldwide>.
- [5] PatrickFarley. *Face detection and attributes concepts - Azure Cognitive Services*. URL: <https://docs.microsoft.com/en-us/azure/cognitive-services/face/concepts/face-detection#face-landmarks>.
- [6] TerryLanfear. *Protection of customer data in Azure*. URL: <https://docs.microsoft.com/en-us/azure/security/fundamentals/protection-customer-data>.
- [7] HeidiSteen. *Create, manage, and secure admin and query api-keys - Azure Cognitive Search*. URL: <https://docs.microsoft.com/en-us/azure/search/search-security-api-keys>.
- [8] *Cognitive Services API Documentation*. URL: <https://westus.dev.cognitive.microsoft.com/docs/services/563879b61984550e40cbbe8d/operations/563879b61984550f30395236>.
- [9] Nicholas Vollmer. *Recital 30 EU General Data Protection Regulation (EU-GDPR)*. Sept. 2018. URL: <https://www.privacy-regulation.eu/en/recital-30-GDPR.htm>.
- [10] *What are identifiers and related factors?* URL: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/what-is-personal-data/what-are-identifiers-and-related-factors/>.
- [11] PatrickFarley. *Face API Overview - Azure Cognitive Services*. URL: <https://docs.microsoft.com/en-us/azure/cognitive-services/face/overview>.
- [12] *Azure products by region: Microsoft Azure*. URL: <https://azure.microsoft.com/en-gb/global-infrastructure/services/?products=cognitive-services%20%EIons>.
- [13] *History of Face Recognition & Facial recognition software*. May 2019. URL: <https://www.facefirst.com/blog/brief-history-of-face-recognition-software/>.

- [14] 24th January 2020 4:24 pm 10th February 2020 4:00 pm. *Met Police start fighting crime with Live Facial Recognition*. Feb. 2020. URL: <https://www.theengineer.co.uk/metropolitan-police-facial-recognition-lfr/>.
- [15] Meilee.ngan@nist.gov. *Face Recognition Vendor Test (FRVT) Ongoing*. Apr. 2020. URL: <https://www.nist.gov/programs-projects/face-recognition-vendor-test-frvt-ongoing>.
- [16] The Engineer. *Last week's poll: Facial recognition technology in the UK*. Mar. 2020. URL: <https://www.theengineer.co.uk/poll-facial-recognition-uk/>.
- [17] *Facial recognition: It's time for action*. Dec. 2018. URL: <https://blogs.microsoft.com/on-the-issues/2018/12/06/facial-recognition-its-time-for-action/>.
- [18] Joy Buolamwini and Timnit Gebru. "Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification". In: *FAT*. 2018.
- [19] Robmazz. *Microsoft compliance offerings - Microsoft Compliance*. URL: <https://docs.microsoft.com/en-gb/microsoft-365/compliance/offering-home?view=o365-worldwide>.
- [20] *Facial recognition technology: The need for public regulation and corporate responsibility*. July 2018. URL: <https://blogs.microsoft.com/on-the-issues/2018/07/13/facial-recognition-technology-the-need-for-public-regulation-and-corporate-responsibility/>.
- [21] *How do we do a DPIA?* URL: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/data-protection-impact-assessments-dpias/how-do-we-do-a-dpia/#how8>.
- [22] *Transparency Note: Azure Cognitive Services Face API*. URL: <https://azure.microsoft.com/en-gb/resources/transparency-note-azure-cognitive-services-face-api/>.
- [23] *Lawful basis for processing*. URL: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/>.
- [24] *Principle (b): Purpose limitation*. URL: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/principles/purpose-limitation/>.

- [25] *Digital Ethics: A guide for professionals of the digital age*. Tech. rep. CIGREF, Oct. 2018. URL: <https://www.cigref.fr/wp/wp-content/uploads/2019/02/Cigref-Syntec-Digital-Ethics-Guide-for-Professionals-of-Digital-Age-2018-October-EN.pdf>.
- [26] *Inside Microsoft*. URL: <https://www.microsoft.com/en-us/diversity/inside-microsoft/default.aspx>.
- [27] *Controllers and processors*. URL: <https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/key-definitions/controllers-and-processors/>.